

ALLGOSANDCOURTCOPYS

Document Management System

Step-by-Step Implementation & Development Plan

Admin & Viewer Roles, with Self-Registration and Admin Approval Workflow

Prepared based on client-provided wireframes / requirement document

Version 1.0

1. Project Overview

ALLGOSANDCOURTCOPYS is a Document Management System (DMS) built to let a government/court office securely store, organize and distribute documents (orders, circulars, GOs, contracts, acts & rules) across departments. The system has two roles: **Admin** and **Viewer** (referred to as "Member" or "User" in the wireframes). Both roles self-register through the app; every Viewer registration must be reviewed and approved by an Admin before the account becomes active. This document lays out a complete, phase-by-phase implementation plan covering every screen shown in the client's wireframes, plus the supporting architecture, database, APIs, security, testing and rollout plan needed to build it.

1.1 Core Objectives

- Allow both Admins and Viewers to self-register (no manual account creation by IT staff required).
- Gate every Viewer account behind an Admin approval step before login is permitted.
- Give Admins full control of departments, folders, files, permissions and viewer accounts.
- Give Viewers a read-first, download-controlled experience scoped to only the folders they are assigned to.
- Provide OTP-based mobile login for Viewers and email/password (or OTP) login for Admins.
- Track every action (uploads, downloads, approvals, logins) for audit and compliance.

1.2 Roles at a Glance

Aspect	Admin	Viewer
Registration	Self-register, then verified by a Super Admin / existing Admin	Self-register via 'Viewer Registration' form
Approval needed	Yes (first admin may be seeded manually; subsequent admins approved by Super Admin)	Yes — Admin must approve before the account is Active
Login method	Email/Password or OTP	Mobile Number + OTP (password optional)
Primary capabilities	Manage departments, folders, files, viewers, permissions, reports, system logs	Browse assigned folders, preview/download files, search, manage own profile
Access scope	Full system	Only folders explicitly assigned by Admin

2. Registration & Approval Workflow (Core Requirement)

This is the central workflow that governs both roles. It is not shown as a distinct screen in the wireframes but is implied by "Create Viewer" (admin-assisted) and "Viewer Registration" (self-service) — the plan below merges both patterns into one consistent, secure flow.

2.1 Viewer Self-Registration & Approval

- **Step 1 — Registration:** Viewer opens the app, taps "Register", and fills the Viewer Registration form (Photo, Full Name, Department, Designation, Mobile Number, optional Password, requested Download Permission). On submit, account status is set to **Pending Approval** (not Active).
- **Step 2 — OTP verification of mobile number:** An OTP is sent to confirm the mobile number is real and reachable, before the request even reaches the Admin queue (reduces spam/fake requests).
- **Step 3 — Admin notification:** A new entry appears under Admin Dashboard → "Permissions Requests" (the counter shown as 23 in the wireframe) and a push/in-app notification is sent to all Admins of that department.
- **Step 4 — Admin review:** Admin opens the request, verifies the person's identity/designation (manually, or against an HR/employee master list if available), and either **Approves** or **Rejects** (with a reason).
- **Step 5 — Folder & permission assignment:** On approval, the Admin assigns the folders the Viewer may access and sets Access Type (View Only / View & Download), matching the "Create Viewer" screen in the wireframe.
- **Step 6 — Activation:** Account status flips to **Active**; Viewer receives an SMS/notification that access is granted and can now log in with Mobile + OTP.
- **Step 7 — Ongoing control:** Admin can Enable/Disable (deactivate) any Viewer at any time from the Viewers List screen — this reuses the same Active/Inactive flag rather than a separate mechanism.

2.2 Admin Self-Registration & Approval

- The very first Admin account is provisioned manually (seeded) during deployment — someone has to be able to approve the second admin.
- Any subsequent Admin who self-registers is placed in a **Pending** state and must be approved by an existing/Super Admin, mirroring the Viewer flow, so no one can grant themselves administrative access.
- Optionally introduce a lightweight **Super Admin** role solely for approving new Admins and viewing system-wide logs — recommended given the sensitivity of court/government data.

2.3 Status State Machine

Status	Meaning	Who can transition it
Pending	Registered, OTP-verified, awaiting Admin decision	System (auto on submit)
Approved / Active	Can log in and use the app per assigned permissions	Admin
Rejected	Registration denied; user notified with reason, may re-apply	Admin
Inactive / Disabled	Previously active account, access suspended	Admin

3. Screen-by-Screen Functional Requirements

Every screen from the client's wireframe PDF is captured below with its required fields, behaviours and validation rules, so nothing from the original document is missed during build.

3.1 Viewer Registration

Self-service sign-up form for Viewers.

- Upload Viewer Photo — JPG/PNG, max 5MB, client-side + server-side validation
- Full Name (required, text)
- Department — dropdown, sourced from the Admin-managed Department list
- Designation (required, text)
- Mobile Number — required, +91 prefixed, 10-digit validation, used as unique login identifier
- Password — optional (OTP login is the default; password enables the alternate email/password path)
- Enable Download Permission — toggle; this is the *requested* value, final value is confirmed by Admin
- Active Account toggle — visible to Admin only; not editable by the Viewer at registration time
- "Create Viewer" submit button — creates record with status = Pending Approval

3.2 Viewer / Member Login

OTP-first login for Viewers on the branded ALLGOSANDCOURTCOPYS screen.

- Mobile Number input with country code selector (default +91)
- "Send OTP" button — triggers SMS OTP via gateway (e.g., MSG91 / Twilio Verify)
- 6-digit OTP input boxes with auto-focus/auto-advance
- Resend OTP countdown timer (45s in wireframe) with a Resend link once expired
- "Verify & Login" — validates OTP, checks account status is Active (blocks Pending/Rejected/Inactive with a clear message), issues session/JWT token
- "Secure Login" trust banner (data safe and encrypted)
- "Don't have access? Contact your administrator" — helper link/text for unapproved users

3.3 Member Profile

Read/edit view of the logged-in Viewer's own details.

- Header: Photo, Name, role badge (Viewer), phone, email, Joined date
- Profile Information: Department, Designation, Mobile Number, Login Method, Download Permission (Enabled/Disabled badge), Assigned Folders count, Last Login timestamp, Account Status badge
- Security section: Change Password, Logout From All Devices
- Logout action
- Edit icon (top-right) to update editable fields (photo, designation, etc.) — changes to Department or Download Permission should re-trigger Admin review, since they affect access scope

3.4 Viewer Home Page

Dashboard landing screen after login.

- Header with app name, notification bell (unread count badge), profile icon
- Welcome card: name, department, last login date/time

- Global search bar: "Search files, folders or departments..." with filter icon
- Stat tiles: Departments (visible/assigned count), Files (available to this viewer), Downloads this month, Last login
- Quick Access grid: Department List, Contract List, Court Orders, Circulars, Government Orders, Acts & Rules, Notifications, Recent Files, Favorites, Downloads, Search Documents, My Profile
- Recent Files list with preview (eye), download (down-arrow) and overflow (■) actions per row — all gated by that file's folder permission

3.5 Side Menu (Menu List)

Slide-out navigation drawer for Viewers.

- Profile summary header (photo, name, department, phone)
- Home, Department List, Contract List
- (Space reserved in wireframe for additional quick links — map to Court Orders, Circulars, GOs, Acts & Rules, Notifications as needed)
- Favorites, Search Documents, My Profile
- Help & Support, Settings, About App, Privacy Policy
- Logout (destructive, red)
- App version footer

3.6 Admin Dashboard

Landing screen for Admins after login, labelled "ADMIN PANEL".

- Welcome card with role (System Administrator), date/time, last login
- Stat tiles: Departments, Files, Downloads (this month), Viewers (total), Permission Requests (pending approvals — feeds the approval workflow in Section 2)
- Quick Actions grid: Add Department, Add Folder, Upload Files, Create Viewer, Manage Permissions, Contract List, Court Orders, Circulars, Reports, System Logs — with a "Customize" option to reorder
- Departments carousel with per-department file counts and an "Open" button; "View All" link
- Recent Files list across all departments, each tagged with its source department
- Bottom navigation: Home, Departments, Files, Viewers, Reports, Settings

3.7 Admin Step-by-Step Workflow (as illustrated)

The client's 8-step admin journey, to be implemented as connected screens/flows:

- 1. Login (email/password or OTP)
- 2. Admin Dashboard overview
- 3. Departments list → tap to open
- 4. Folders inside a Department (e.g., Office Orders, Schemes, Reports, Budget, Audit) with file counts
- 5. Files inside a Folder — list with preview/overflow actions, "+" to add new files
- 6. Upload Files — drag-and-drop or Browse, multi-file with per-file progress/status (Uploaded/Uploading %/Pending), Cancel All
- 7. Create Viewer — Admin-assisted creation mirroring the self-registration fields, plus Assign Folders and Access Type (View & Download / View Only) pickers
- 8. Viewers List — All / Active / Inactive tabs, per-viewer department + phone, overflow menu to enable/disable, edit, or reassign folders

3.8 Viewer Dashboard — Full Journey (as illustrated)

The client's 12-step viewer journey:

- 1. Login (Mobile + OTP) 2. Dashboard with accessible folders + recent files 3. View Accessible Folders 4. Open Folder → file list 5. Preview File (in-app viewer for PDFs/images/docs) 6. Download File (progress indicator, respects Download Permission) 7. Search Files within a folder 8. File Options menu (Preview, Download, Share, File Info) 9. Downloads screen (All / In Progress tabs) 10. My Profile (view details, logout) 11. Notifications (new file added, folder updated) 12. Access Restricted screen — shown whenever a Viewer opens a folder/file outside their assigned scope, with a "Go Back" action.

4. Recommended System Architecture

4.1 Suggested Tech Stack

Layer	Recommendation	Notes
Mobile App (Viewer)	React Native + TypeScript (single codebase for Android + iOS)	Reuses components/types with the React TS admin panel; alt: React TS as a mobile-responsive PWA
Admin Web Panel	React.js + TypeScript + Tailwind / MUI	So Admins can work from a desktop browser as well as the mobile app
Backend API	Java + Spring Boot (Spring Web, Spring Security, Spring Data JPA)	REST APIs; modular structure mapping to Departments/Folders/Files/Viewers/Registration-Approval
Database	PostgreSQL	Relational integrity for departments→folders→files, roles, permissions; JSONB for flexible metadata
File Storage	AWS S3 / Azure Blob / on-prem MinIO (govt data may require local hosting)	Store originals + generate thumbnails/preview renditions
OTP / SMS	MSG91, Twilio Verify, or a govt-approved SMS gateway	India DLT registration required for SMS templates
Auth	Spring Security + JWT (access + refresh tokens), BCrypt password hashing	Short-lived access token, device-bound refresh token
Push Notifications	Firebase Cloud Messaging	For the bell icon / new-file alerts
Hosting	Govt-empanelled cloud (NIC/MeghRaj) or AWS/Azure, per client's compliance needs	Confirm data residency requirement before final selection

4.2 High-Level Component Diagram (textual)

Mobile App (Viewer) & Web/Mobile Admin Panel → API Gateway → Auth Service (OTP/JWT) → Core API (Departments, Folders, Files, Permissions, Viewers, Notifications) → PostgreSQL (metadata) + Object Storage (file binaries) → Background Workers (thumbnail generation, notification dispatch, audit log writer) → SMS/Push Gateways.

5. Database Schema (Core Tables)

Table	Key Fields
users	id, full_name, mobile_number (unique), email, password_hash (nullable), photo_url, role [admin viewer], department_id, designation, download_permission (bool), status [pending active rejected inactive], created_at, last_login_at
departments	id, name, description, created_by, created_at
folders	id, department_id, name, parent_folder_id (nullable, for sub-folders), file_count, created_by, created_at
files	id, folder_id, file_name, file_type, size_bytes, storage_path, uploaded_by, uploaded_at, version
viewer_folder_accesses	id, viewer_id, folder_id, access_type [view view_download], granted_by, granted_at
registration_requests	id, user_id, requested_role, status [pending approved rejected], reviewed_by, review_note, reviewed_at
downloads	id, viewer_id, file_id, downloaded_at, status [completed in_progress failed]
favorites	id, viewer_id, file_id, created_at
notifications	id, user_id, title, body, type, is_read, created_at
otp_verifications	id, mobile_number, otp_hash, purpose [registration login], expires_at, verified_at
audit_logs	id, actor_id, action, entity_type, entity_id, metadata (JSON), created_at

6. Core API Endpoints

Endpoint	Method	Purpose
/auth/register	POST	Self-registration for Admin or Viewer (creates Pending record)
/auth/otp/send	POST	Send OTP for registration or login
/auth/otp/verify	POST	Verify OTP, issue session token if Active
/auth/login	POST	Email/password login (Admin)
/admin/registration-requests	GET	List pending Viewer/Admin approval requests
/admin/registration-requests/{id}/approve	POST	Approve, assign folders + access type
/admin/registration-requests/{id}/reject	POST	Reject with reason
/admin/viewers	GET/POST	List / create viewers directly
/admin/viewers/{id}/status	PATCH	Enable / disable a viewer
/departments	GET/POST/PUT/DELETE	Manage departments
/departments/{id}/folders	GET/POST	List / create folders in a department
/folders/{id}/files	GET/POST	List / upload files in a folder
/files/{id}/preview	GET	Stream a preview rendition of a file
/files/{id}/download	GET	Download original file (permission-checked)
/viewers/{id}/permissions	GET/PUT	View / update a viewer's folder access list
/search	GET	Search files/folders/departments (scoped to caller's access)
/notifications	GET	List notifications for the logged-in user
/reports	GET	Usage/download/activity reports for Admin
/system/logs	GET	Audit log viewer for Admin

7. Step-by-Step Development Plan

A phased delivery plan is recommended so the registration/approval workflow — the most critical and cross-cutting requirement — is built and tested early, before dependent features (permissions, downloads) are layered on top.

Phase 0 — Discovery & Setup (Week 1)

- Finalize requirements sign-off against this document and the client wireframes
- Confirm hosting/compliance constraints (data residency, SMS gateway approval, DLT registration)
- Set up repos, CI/CD pipeline, cloud environments (dev/staging/prod), and project management board
- Finalize UI design system (colors, typography) matching the navy/blue branding shown in wireframes

Phase 1 — Core Backend Foundations (Weeks 2-3)

- Database schema implementation (Section 5)
- Auth service: registration, OTP send/verify, JWT issuance, password hashing
- Role & permission model (Admin / Viewer, status state machine from Section 2.3)
- Department, Folder, File CRUD APIs with file storage integration

Phase 2 — Registration & Approval Workflow (Weeks 3-4)

- Viewer self-registration API + validation (photo upload, mobile uniqueness, OTP gate)
- Admin registration-requests queue API + notification trigger on new submissions
- Approve/Reject endpoints with folder assignment + access-type selection
- Status-based login gate (block Pending/Rejected/Inactive with clear error messaging)
- End-to-end test: register as Viewer → Admin approves → Viewer can log in

Phase 3 — Admin Panel / App (Weeks 4-6)

- Admin login (email/password + OTP option)
- Admin Dashboard (stat tiles, quick actions, recent files, department carousel)
- Departments → Folders → Files navigation and management screens
- Upload Files screen with multi-file drag-and-drop + progress states
- Create Viewer screen (admin-assisted registration) and Viewers List (All/Active/Inactive, enable/disable)
- Permission Requests screen tying into Phase 2 APIs

Phase 4 — Viewer App (Weeks 6-8)

- Viewer Registration screen + Viewer Login (OTP) screen
- Viewer Home dashboard (stat tiles, quick access grid, recent files)
- Side menu / navigation drawer
- Folder browsing, file preview (PDF/image/doc renderer), download with permission checks
- Search (global + in-folder), Favorites, Downloads screen (All/In Progress)
- Access Restricted screen for out-of-scope folders/files
- Notifications screen + push notification wiring

Phase 5 — Profile, Reports & Admin Extras (Week 9)

- My Profile screens for both roles (view + edit, change password, logout-all-devices)
- Admin Reports & Analytics (downloads, active viewers, storage usage)
- System Logs / audit trail viewer for Admin
- Settings, Help & Support, About App, Privacy Policy static screens

Phase 6 — QA, Security Hardening & UAT (Weeks 10-11)

- Functional QA against every screen in Section 3
- Security testing: auth flows, file access authorization, OTP abuse/rate limiting, upload validation
- Performance/load testing on file upload & download endpoints
- User Acceptance Testing with the client using real department/folder data

Phase 7 — Deployment & Handover (Week 12)

- Production deployment, DNS/SSL, SMS gateway go-live, backup & monitoring setup
- Seed first Admin account, initial department/folder structure
- Admin training session + user documentation
- Warranty/support window for post-launch fixes

8. Security & Compliance Considerations

- OTP rate limiting and expiry (e.g., 5 attempts, 5-minute expiry) to prevent brute force / SMS-bombing.
- Role-based access control (RBAC) enforced at the API layer, not just hidden in the UI — every file/folder request must check the caller's viewer_folder_access entry.
- All file downloads and previews logged in audit_logs (who, what, when) — required for court/government document trails.
- Encryption in transit (TLS) for all traffic; encryption at rest for the file storage bucket.
- Admin approval step (Section 2) is the primary safeguard against unauthorized access — must be enforced server-side, never assume the client app hides a Pending account correctly.
- Passwords (where used) hashed with bcrypt/argon2; never stored or logged in plain text.
- Regular automated backups of both the database and file storage, with a tested restore procedure.
- Data residency: confirm whether court-related documents must remain on government-approved infrastructure before finalizing the hosting provider.

9. Testing Plan Summary

Test Type	Focus
Unit tests	Auth logic, permission checks, OTP generation/validation, status transitions
Integration tests	Registration → Approval → Login → Folder access end-to-end flows
Security tests	Access-control bypass attempts, OTP abuse, file path/authorization checks
UI/UX QA	Every screen in Section 3 against the client's wireframe pixel-for-pixel where practical
Performance tests	Concurrent uploads/downloads, large file handling, search response time
UAT	Client Admin and sample Viewers run real registration + document workflows before go-live

10. Deliverables Checklist

- Viewer mobile app (Android + iOS) covering all screens in Sections 3.1–3.5 and 3.8
- Admin app/panel covering Sections 3.6–3.7
- Backend API + database implementing Sections 4–6
- Registration & approval workflow (Section 2) fully enforced server-side
- Deployed production environment with monitoring, backups and SSL
- Admin training + handover documentation

End of document.